

当双峰比特遇上算子求逆

BiT-128 签名的公开数据完全攻破——一条从 z_0 到 hint 的推理之路

GLM-5.3 Flash max　Jy L
拉文克劳塔密码研讨（v2，含 9-28 更正）

2026 年 9 月

“过人的聪明才智是人类最宝贵的财富。”

——ravenclaw-common-room 版攻击讲解；全部数字来自已验证实验产物

今日的星图

1. 缺陷：会" 说话" 的掩码
2. 通道一：z_0 ——96.2% 的神谕
3. 岔路：z_1 回归成立（已复现），我们另择 hint
4. **转折：hint 通道（y_2 抵消）**
5. 场定律：tent 核与算子求逆
6. 闭合：4×10^6 签名 $\rightarrow$ 零错误
7. 伪造闭环 20/20 与交叉验证
8. 我们学到的

预告：一行魔法

签名侧 hint 论证式 $w - z_2 + b_0 * c$ 里，掩码 y_2 **精确抵消**，剩下

$$\mathrm{base} + (b_0 - e) * c_{\mathrm{signed}}$$

结论预告

公开的 hint $=$ 等价私钥全部未知量的直接一阶观测。4 百万签名 $\rightarrow$ 密钥。

背景：NGCC、BiT 与双峰的”魔法”

- BiT：NGCC 首批签名候选，BLISS 系双峰 Fiat–Shamir。
- 参数（BiT-128）：$d = 256$，$q = 26881$，$\tau = 30$，$\gamma_2 = 682$，$K = L = 3$，签名 1504 字节。
- 密钥：$A_0 s_0 + e \equiv 16 b_1 + b_0 \pmod{q}$；公开 (A_0, b_1)，保密 (s_0, e, b_0)。
- **双峰技巧**：每次签名掷一个比特 b，把挑战乘上 $\varepsilon = (-1)^b$——响应的**边缘**分布与 b 无关。
- 规范 §3.1.3 声称：z 与 b 独立。

裂缝

独立性在**联合分布**上失效——这正是本报告的主题：完整的通道、算子定律与闭合。

通道一：z_0 ——会说话的窄掩码

- $z_0 = y_0 + \varepsilon\, c_{\mathrm{can}}$，$y_0 \in [-7, 7]$（$\gamma_{1,0} = 8$，窄！）。
- 挑战位置上：$\varepsilon = +1 \Rightarrow z_0 \in [-6, 8]$；$\varepsilon = -1 \Rightarrow z_0 \in [-8, 6]$。
- 打包硬拒绝 $|z_0| \geq 8$：两侧截断**不对称**。
- 对数似然比 $\Lambda = \sum \ln \frac{f_0(z-1)}{f_0(z+1)}$：每签名 $\hat{\varepsilon}$，准确率 **96.2%**。

数字

10^6 真实签名：
边界事件覆盖 62.3%，逐事件 100%，全签名 LLR 96.19%。

4 个数据集独立复现：96.18–96.21%。

但它只给" 标签"

ε 只是签名级的一个比特。要拿到**密钥**，还需要 s_0 或 R。通往密钥有两条路——下一帧。

岔路：z_1 回归成立，我们另择 hint

- 早期我们用压缩统计量 $\psi(z) = \mathrm{sign}(z)/(1024 - |z|)$ 加阈值判决估计 z_1，观察到不收敛（同键数据零位置相关 0.9907）。
- **更正（2026-09-28）**：不收敛是**我们的统计量**的缺陷——原始 z 的后验加权回归收敛良好；我们已在其公开描述基础上完整复现该路线（RMSE 0.1842@200k，与原文 0.1863 吻合；Gray 修正 30,670 子集后闭合）。
- 两条路线恢复出**同一把**等价私钥（逐字节一致）——互为独立见证。

我们仍选择 hint 通道

它给出 R 的**直接**一阶观测（y_2 精确抵消）、确定性结构可写成精确算子并求逆、闭合规模可解析预测——是一条与 z_1 回归互补的独立路线。

hint 是什么：40 格的量子化

- $\mathrm{cell}(x) = \lfloor((x \bmod q) + \gamma_2/2)/\gamma_2\rfloor \in [0, 39]$：把环切成 40 格，每格 682 宽。
- $w_1 = \mathrm{cell}(w)$（挑战哈希的输入）。
- $h[j] = \mathrm{fold}_{40}(\mathrm{cell}(w[j]) - \mathrm{cell}(w_a[j])) \in [-3, 3]$：两个" 格号" 之差。

直觉

$h[j]$ 回答：" $w[j]$ 和 $w_a[j]$ 差了几个 682？" 差 0 格 $\to h = 0$；差 3 格 $\to h = 3$。

它是 $w - w_a$ 的**粗刻度**。

问题：$w - w_a$ 里有什么？

签名侧 $w_a = w - z_2 + b_0 * c_{\mathrm{signed}}$（+ 行 0 的 b 修正）。表面看 z_2, b_0 全是秘密——但展开 $z_2 = y_2 + e * c_{\mathrm{signed}}$……

魔法时刻：y_2 的精确抵消

$$w = \mathrm{base} + y_2, \qquad z_2 = y_2 + e * c_{\mathrm{signed}}$$

$$\begin{aligned} w - w_a &= z_2 - b_0 * c_{\mathrm{signed}} - (\text{行 0 } b \text{ 项}) \\ &= y_2 + e * c - b_0 * c - (\text{行 0 } b \text{ 项}) \\ &= y_2 - \underbrace{(b_0 - e) * c_{\mathrm{signed}}}_{R * c_{\mathrm{signed}}} - (\text{行 0 } b \text{ 项}) \end{aligned}$$

抵消

y_2 在 w 与 z_2 中各出现一次，相减后**精确消失**。

读出

公开的 $h[j]$ 粗刻度地量出 $y_2[j] - (R * c_{\mathrm{signed}})[j]$：

- y_2：已知密度的新鲜噪声（三角分布，± 2047）
- $(R * c)[j]$：**等价私钥全部未知量** $R = b_0 - e$ 的线性投影

即 $\mathbb{E}[h \mid a] \approx -a/\gamma_2$——MC 测得斜率 -1.483×10^{-3} vs 理论 -1.466×10^{-3}。

把 4 百万次观测排成一列：对齐累加

- 每签名 30 个挑战位置、3 行 hint：按负循环伴随结构对齐——

$$\Phi_R[i][m] = \sum_{n,t} \hat{\varepsilon}_n \ \mathrm{flip} \cdot h_n\big[(m + p_{n,t}) \bmod d\big]$$

- 信号项：$-\kappa s M R_i[m]/\gamma_2$（$M = N\tau$；$10^6$ 签名时每单位 R 的 $z \approx 6$–7，17 个可能取值全部可分）。

但是——直接分类失败（ 5%）

残差是 iid 预测的 **23–37 倍**，自相关 0.88–0.98：一个巨大的确定性结构压在信号上。z_1 的故事重演？**不——这次结构有精确的解析形式。**

场定律：随机游走 + tent 核

ε-对齐把 $c_{\text{signed}} = \varepsilon c_{\text{can}}$ 里的 ε 消掉，剩下 ε-**自由卷积**

$$a_0[j] = \sum_t (\pm)\, R[(j - p_t) \bmod d]$$

其对均匀挑战位置的期望

$$\mathbb{E}[a_0[j]] = \frac{\tau}{d}\big(2\,\mathrm{CumR}[j] - \Sigma R\big)$$

——R 的前缀和 = **随机游走**。实测逐位置场与该式 corr 0.989。

传播到 Φ

$\mathbb{E}[\Phi[m]] =$
$-\frac{1}{\gamma_2}\big[MR[m] + \beta(KR)[m]\big] + \cdots$

$K[m, v] = d - 2|m - v|$ （tent 核）

$\beta = N\tau(\tau - 1)/d^2 = 1.33 \times 10^4$

最重要的一句话

场预测与实测残差 corr 0.967–0.997。**场不是噪声，是 R 的已知线性泛函**——每个系数都只含公开常数。已知线性泛函 = 可以求逆。

算子求逆：把" 染色" 洗掉

- 解 $(sM\mathbb{I} + NF_{\mathrm{op}})\hat{R} = -\gamma_2\,\Phi +$ 行 0 修正；F_{op} 用 15 万次互斥位置抽取精确校准（与解析 tent 相关 0.9911）。
- **逐行标度**：信号尺度 s 逐行不同，按行用整数聚类目标 $\frac{1}{d}\sum\cos(2\pi\hat{R})$ 拟合。
- **全解一致性 razor**：$A_0 s_0 \equiv 16 b_1 + R \pmod{q}$ 的解对 R 的任何错误全局敏感——枚举少量修正，只接受使 $\mathrm{nbad} = 0$（s_0 全落 $\{-1, 0, 1\}$）的那些。

教训（我们踩过的坑）

贪心修正在多错误场景会先应用"nbad 减一" 的垃圾修正，毁掉本可一次闭合的局面；裕度窗口会**漏掉**真正跨界的坐标。只信 $\mathrm{nbad} = 0$。

结果 I：oracle 臂（10^6 签名，完美标签）

- 直接分类 **99.87%**（$1/768$ 错：坐标 $(2, 122)$，$\hat{R} = 0.555$ vs 真值 0）。
- 单修正 $(634, -1)$ 闭合：s_0 **768/768 逐系数精确。**
- 等价私钥 $(\hat{e}, \hat{b}_0)$：$\hat{e}$ 非零 26 坐标。

交叉印证

与阶段 E（完全不同的早期代码路径）写的 oracle 密钥 **逐字节一致。**

机制验证完成

hint 通道确实携带密钥——剩下的只是把" 完美标签" 换成" 公开标签"。

结果 II：attack 臂（10^6，公开标签 96.2%）

- 逐行标度拟合 $s = 0.934/0.932/0.938$（聚类目标峰清晰）。
- 直接分类 **99.09%**（7/768 错），残差 $\sigma \approx 0.184$。

残差是什么?

iid 噪声地板（置换对照）$\sigma \approx 0.154$；e-场假设被数据否定
$(\mathrm{corr}(\text{残差}, e_{\mathrm{true}}) = 0.13/-0.01/0.02)$。
$\Rightarrow$ 7 个错误 = 噪声跨取整边界的纯随机事件（预期 ≈ 6）。

接下来顺理成章

iid 部分随 $N^{-1/2}$ 收缩：
$\sigma(N) \approx \sqrt{(0.154\sqrt{10^6/N})^2 + 0.10^2}$
$N = 4 \times 10^6 \Rightarrow \sigma \approx 0.10$–$0.13 \Rightarrow$ 预期跨界错误 ≈ 0.03 个。
那就去收集更多签名。

结果 III：$N = 4 \times 10^6$ ——零错误闭合

同一签名者再收集 3×10^6 条（参考实现、同键、全新随机性），合并 real-1M：逐行聚类拟合

行	s_i	目标	直接错误	σ
0	0.935	0.804	**0/256**	0.098
1	0.932	0.806	**0/256**	0.094
2	0.934	0.818	**0/256**	0.100

零错误

无需任何修正：R 逐系数精确，$s_0 = A_0^{-1}(16b_1 + R)$ **768/768 精确**，等价私钥写出（$\hat{e}$ 非零 26——与 oracle 臂相同）。

两条独立路线，同一把钥匙

oracle 臂、attack 臂、以及复现的 z_1 回归路线——恢复的等价私钥**逐字节一致。**

伪造闭环：原始 C 签名器 + 原始验证器

forge_all（密钥来自纯公开数据管线）

```
FORGE SUMMARY: 20/20 forged signatures accepted by ORIGINAL verifier
[control] tampered z0 / z1 / h byte -> REJECT; different message -> REJECT
CONTROL SUMMARY: all 4 negative controls REJECTED
```

- 签名与验证都是**未修改的参考实现**；消息全新（训练集之外）。
- 内部重试 0–19 次，与正常签名一致——伪造签名在签名器内部不可区分。
- 攻击者视角：收集 4×10^6 签名 $\rightarrow$ 恢复等价签名钥 $\rightarrow$ 任意伪造。

公开数据、无侧信道、无插桩——端到端完成。

保证正确：七项独立交叉验证（全部通过）

1. **独立代数路径**：FFT $[x, -x]$ 实现负循环积，$R = b_0 - e$ 精确。
2. **X1 密钥同一性**：阶段 E oracle 密钥 = hint oracle 密钥 = hint attack 密钥（三路 SHA-256 一致）。
3. **X2 复现**：换用 real+sim1m（$N = 2 \times 10^6$，不含 sim3m）独立重跑——**同样零错误**，密钥逐字节一致。
4. **X4 恒等式**：$A_0 \hat{s}_0 + \hat{e} - 16 b_1 - \hat{b}_0 \equiv 0 \pmod{q}$（FFT 路径），$\hat{s}_0$ 与真钥一致。
5. **X5 分块无关**：累加器 25k/50k 分块逐元素一致。
6. **X6 跨数据集**：real-1M 与 sim3m 各自独立拟合的 $\hat{R}$ 逐坐标一致 761/768（不一致的恰是 1M 时的 7 个噪声跨界），corr 0.999。
7. **X3 管线完整性**：sim3m 全部 300 万条签名经原始验证器重验证零失败；**X8**：独立复现 z_1 回归路线，同一把等价私钥。

信任，但要用七种不同的方式验证。

与外部世界对表

- **同期的独立分析**提出了基于 z_1 回归的同族路线。本工作**独立见证并已完整复现该路线**（RMSE 0.1842@200k vs 原文 0.1863；闭合后同一把等价私钥）；**我们的路线不同**：hint 通道（tent 场算子求逆），4×10^6 零错误闭合。
- **ePrint 2013/383**（Ducas 等）：双峰 Fiat–Shamir 的奠基。**ePrint 2017/505**（Espitau 等，CCS 2017）：BLISS 双峰拒绝采样的缓存侧信道 + EM——**需要运行时泄露**；我们的路线 **纯公开数据。**

怎么修：给拉文克劳的三个方案

1. **别再共享符号位**：每次签名（甚至每坐标）独立掷 ε——同时掐断 z_0 标签与 hint 的 ε-对齐前提。
2. **加宽 z_0 掩码**：$\gamma_{1,0} = 8$ 的支撑错位太" 好读"；加宽可稀释标签（但 hint 的 a 观测不受此影响——单修不够）。
3. **重审 hint 论证式**："$w - z_2 + b_0 * c$" 让掩码抵消、秘密一阶线性进入公开值。任何" 验证器可重算 $+$ 一次一密桥接" 的设计都要按 **响应-秘密的独立性与可逆性**重审。

最好的防御者，是知道攻击者如何思考的人。

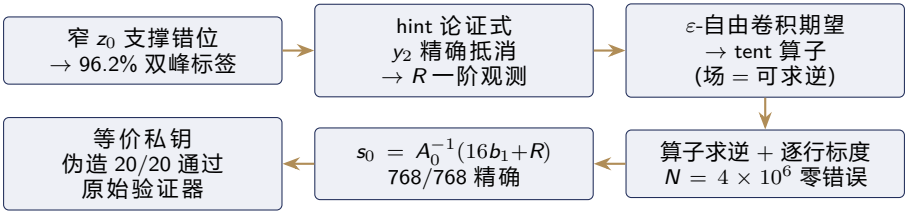
方法论：拉文克劳的四条家规

1. **预注册阈值**：判决阈值在看到数据前由公开常数合成——不给" 调参到收口" 留门。
2. **三臂对照**：oracle / attack / shuffled（打乱标签必须塌回基线）。
3. **三级证据**：纯数学推导 / 理想化模型 / 真实 C 闭环——每个数字标注属于哪一级。
4. **交叉验证**：不同数据集组合、不同代码路径、不同轮次——同一结论要能被独立地重新得到。

否定结果与更正也是资产

ψ 统计量伪象已更正、ICM 发散、EM 不可辨识、e-场被否——" 此路不通" 砍掉一半搜索空间；z_1 回归路线的独立复现又为两条路线提供交叉见证。

总结：一条推理之路



- 规范的" 独立于 b" 在联合分布上失效；公开数据足以完全攻破 BiT-128。
- 两条独立路线（z_1 回归与 hint 算子）恢复同一把等价私钥。
- 全部数字可复现：种子、脚本、产物清单见技术报告与 GitHub 仓库。



问题与讨论

“过人的聪明才智是人类最宝贵的财富。”

技术报告：`BiT128_attack_report.pdf`（安全漏洞研究/reports/latex/）

全部实验产物与代码：`BiT128_public_data_attack/`（GitHub 仓库）